CYBR373
Assignment 1

Qualitative Risk Assessment

2024

Ricky Fong
300500545

Classification definitions

CIA

CIA Triad	Requirements
Confidentiality	Ensure that assets are viewed only by authorised parties.
Integrity	Ensure that assets are modified only by authorised parties in authorise way, accurate and complete.
Availability	Ensure that assets are available to authorised parties when needed.

Value	Description
Confidential	Used for the most sensitive corporate information that must be tightly controlled, even within the organisation. This information must be securely stored and accessed only by authorised personnel. Highly sensitive data intended for specific use or group of individuals with a legitimate need-to-know.
Private/Internal	Used for information are intended for internal user within the organisation. This information is only restricted to employees, contractor and third parties. Data is sensitive but not critical as confidential. [1]
Public	Used for Information that are freely shared with the public for use. This data has minimal impact on the organisation that not critical to private or internal or confidential. [1]

Likelihood

Likelihood	Description
Certain	It is almost certain that a threat will exploit a vulnerability.
Highly probable	It is feasible for a threat to exploit the vulnerability.
Possible	There is a possibility that a threat could exploit a vulnerability.
Possible but unlikely	It is unlikely, but possible for a threat to exploit the vulnerability.
Almost never	It is very unlikely for a threat to exploit the vulnerability

Impact

Impact	Description
Severe	There is economic loss. There is loss of life. Legal liabilities and/or breach of SLAs. There is loss of corporate or public image. Communications and recovery must be shared with customers. Severe impact on business operations.
Significant	Considerable economic loss. There is significant loss of life. Major legal implications. There is a significant loss of corporate or public image. Communications and recovery being shared with customers. Considerable impact on business operations.

Moderate	Noticeable economic loss. Injuries. Some legal implications. There are a few losses of corporate or public image. Communications and recovery perhaps being shared with customers Moderate impact on business operations.
Minor	Minimal economic loss. Minor legal implications. Insignificant communications and recovery being shared with customers. Slight impact on business operations.
Minimal	Negligible economic loss. Insignificant legal implications. No communications and recovery being shared with customers. No noticeable impact on business operations.

Valuation Criteria

Impact	Description
High	It will result in a loss of concern between EtherSpace and its customers or result in a large legal action or cause EtherSpace significant revenue or earnings.
Medium	It will result in moderate economic or reputational damage to EtherSpace.
Low	It will result in minimal economic or reputational damage to EtherSpace.

Information assets and classifications

People Assets

Item ID	Asset Category	Asset Name	Asset Description/Attribute
P001	Employees	CEO	Role: CEO
P002	Employees	Engineer 1	Role: Engineer
P003	Employees	Engineer 2	Role: Engineer

Hardware Assets

Item ID	Asset Category	Asset Name	Asset Description/Attribute
H001	Hardware	Server	Description: High density heat and dedicated servers. Quantity: 24. Category: Systems and peripherals. Location: Wellington CBD.
H002	Hardware	Desktop PCs	Description: Dedicated Desktop PCs running Ubuntu. Quantity: 3. Category: Systems and peripherals. Location: EtherSpace Office.

H003	Hardware	NAS Drive	Description: Network Attached Storage for transactional data backups. Quantity: 1. Category: Systems and peripherals. Location: Office supply room.
H004	Hardware	Routers	Routers to manage network traffic. Quantity: 3. Category: Networking Equipment. Location: EtherSpace office.
H005	Hardware	Switches	Description: 24 Port Switches for internal networking. Quantity: 11. Category: Networking Equipment. Location: EtherSpace office.
H006	Hardware	RFID key access	Description: A key is provided to all employees for access to their own office, the office supply room, and the server room. Quantity: 1 per employee. Category: Systems and peripherals. Location: EtherSpace.
H007	Hardware	Air Conditioning	Description: Cooling systems for the data centre. Quantity: 1. Category: Facility. Location: EtherSpace server room.
H008	Hardware	Smoke Detectors	Description: Smoke detectors for fire detection. Quantity: 4. Category: Facility. Location: 2 in EtherSpace main office and 2 in server room.
H009	Hardware	Power Distribution Module	Description: Ensures stable power supply to all servers. Quantity: 2. Category: Facility. Location: EtherSpace server room.
H010	Hardware	Web servers (WebM)	Description: Server hosting the VPS management interface. Quantity: 1. Category: System Components. Location: EtherSpace server room.
H011	Hardware	Data link	Description: 10 Gbps primary link for data transmission. Category: System Components. Location: Wellington (CBD).

Software Assets

Item ID	Asset Category	Asset Name	Asset Description/Attribute
S001	Software	OS Linux Ubuntu	Description: Operating system used by staff.
S002	Software	VPS Management Interface	Description: Interface for managing VPS services.
S003	Software	Firewall	Description: Free software used to protect the internal network.
S004	Software	Customer Management Software	Description: In-house software for managing customer accounts.

S005	Software	OpenOffice	Description: Free software used for document processing [2].
S006	Software	Hypervisor	Description: Software for managing virtual servers, running on Debian 11.
S007	Software	SSH Service	Description: Secure Shell service used for encrypted remote access to VPS.
S008	Software	RFID access software	Description: Software used to manage and control physical access through RFID systems.

Physical Assets

Item ID	Asset Category	Asset Name	Asset Description/Attribute
PH001	Physical	Office Doors	Description: RFID controlled door.
PH002	Physical	Windows	Description: Windows on break room and CEO's office.
PH003	Physical	Office Space	Description: The entire office area, office 1, 2, 3, break room, kitchen and office supply room.
PH004	Physical	Employee Workstations	Description: CEO & Engineer desks and equipment.
PH005	Physical	Safe	Description: Contains employment documents, private info.
PH006	Physical	Office Supplies	Description: Stationery and other office supplies, stored in Office Supply Room.
PH007	Physical	Intelligent Airflow	Description: System used to optimise cooling and manage airflow in the data center to prevent overheating.
PH008	Physical	Air Conditioning	Description: Cooling systems for the data centre. Quantity: 1. Category: Facility. Location: EtherSpace server room.
PH009	Physical	Smoke Detectors	Description: Smoke detectors for fire detection. Quantity: 4. Category: Facility. Location: 2 in EtherSpace main office and 2 in server room.
PH010	Physical	Power Distribution Module	Description: Ensures stable power supply to all servers. Quantity: 2. Category: Facility. Location: EtherSpace server room.

Data Assets

Item ID	Asset Category	Asset Name	Asset Description/Attribute
D001	Data	Transactional Data	Description: Data about customer transactions and services purchased. Includes customer personal data and service details.

D002	Data	Customer Data	Description: Data stored by customers on their VPS.
D003	Data	Backup Data	Description: Weekly backups stored on NAS.
D004	Data	Administrative Data	Description: Financial and Human resource data of the company.
D005	Data	Employee Records	Description: Personal information of employees.
D006	Data	Service Information	Description: Information about services offered (Basic, Advanced, Premium).

Data Assets Valuation

Item ID	Asset Category	Asset Name	Loss of Confidentiality	Loss of Integrity	Loss of Availability
D001	Data	Transactional Data	High	High	High
D002	Data	Customer Data	High	High	High
D003	Data	Backup Data	Medium	High	High
D004	Data	Administrative Data	High	High	Medium
D005	Data	Employee Records	Medium	High	Medium
D006	Data	Service Information	High	Medium	High

Assets Prioritisation

Weight table

Impact	Description
Low (0-30)	If the asset is compromised, there is very little to no effect on the company's revenue or public image.
Medium (30-60)	The compromise of the asset has a moderate impact on the company's revenue or public image.
High (60-100)	The compromise of the asset has a significant impact on the company's revenue or public image, potentially causing substantial financial or reputational damage.

Asset ID	Asset Name	Impact on Revenue (0-100)	Impact on Public Image (0-100)	Weighted Score (rounded to whole numbers)
D001	Transactional Data	90	85	88
D002	Customer Data	85	80	83
D003	Backup Data	70	60	65
D004	Administrative Data	75	65	70
D005	Employee Records	60	55	58

D006	Service Information	50	45	48
H001	Servers	95	90	93
H002	Desktops	50	45	48
H003	NAS Drive	80	70	75
H004	Routers	70	65	68
H005	Switches	70	65	68
H006	RFID Key Access	65	60	63
H007, PH008	Air Conditioning	40	30	35
H008, PH009	Smoke Detectors	30	25	28
H009, PH010	Power Distribution Module	85	75	80
H010	Web Servers	90	85	88
H011	Data Link	85	80	83
S001	OS Linux Ubuntu	60	55	58
S002	VPS Management Interface	90	85	88
S003	Firewall	75	70	73
S004	Customer Management Software	85	80	83
S005	OpenOffice	40	30	35
S006	Hypervisor	90	85	88
S007	SSH Service	75	70	73
S008	RFID Access Software	70	65	68
PH001	Office Doors	40	30	35
PH002	Windows	30	20	25
PH003	Office Space	50	45	48
PH004	Employee Workstations	60	55	58
PH005	Safe	60	55	58
PH006	Office Supplies	20	15	18
PH007	Intelligent Airflow	50	40	45

Vulnerability Assessment List

Asset ID	Asset Name	Threat	Vulnerability
P001	CEO	Social Engineering	- High-profile target. - Lack of social engineering training.
P002, P003	Engineer 1 & 2	Accidental Insider Threat	- Fail to follow procedures. - Lack of security awareness. - Improper use of access privileges.
P002, P003	Engineer 1 & 2	Theft	- Access to sensitive areas, no audit logs taken place.
H001	Servers	Theft	- No two-factor authentication door on the sever room.

H002	Desktop PCs	Theft	- Easy to remove.
H003	NAS Drive	Data loss, Theft	- No two-factor authentication door on the supply room. - Lack of encryption/software update, accessible to unauthorised personnel. [3]
H004	Routers	Outdated Technology	- Older hardware with no security updates.
H005	Switches	Outdated Technology	- Outdated firmware, difficult to replace due to exclusive ownership.
H006	RFID Key Access	Unauthorised Access	- Weak encryption of RFID signals. - Cloning RFID cards.
H007, PH008	Air Conditioning	Failure	- Only single cooling unit, no backup system in place.
H008, PH009	Smoke Detectors	False Negatives	- Not regularly tested, may fail to detect smoke in critical areas.
H009, PH010	Power Distribution Module	Power Failure	- No surge protection, risk of power fluctuations.
H010	Web Servers	Data Breach	- Outdated SSL certificates, leading to Man-in-the-Middle Attack [4].
H011	Data Link	Data Interception	- No encryption on data transmissions.
S001	OS Linux Ubuntu	Unauthorised Access	- Weak or misconfigured user permissions, allowing privilege escalation.
S002	VPS Management Interface	Unauthorised Access	- Weak authentication mechanisms. - Lack of multi-factor authentication.
S003	Firewall	Bypass	- Misconfigurations firewall. - Outdated ruleset. - Lacks advance threat detection features.
S004	Customer Management Software	Insider Threat	- Lack of adequate logging and monitoring.
S005	OpenOffice	Outdated Software	- No patches for new vulnerabilities, the latest update is from 2023 [5].
S006	Hypervisor	Resource Exhaustion	- Lack of proper resource allocation controls cause denial of service [6].
S007	SSH Service	Unauthorised Access	- Weak passwords, leading to brute force or dictionary attacks.
S008	RFID Access Software	Insider Threat	- Lack of monitoring or logging, making it difficult to detect misuse

			by authorised personnel.
PH001	Office Doors	Power Failure	- Lack of backup power, causing the doors to fail open or locked when there a power outage.
PH002	Windows	Break-In	- No alarms on windows when break in.
PH003	Office Space	Insider Threat	- External contractors could misuse their access to steal or sabotage the room.
PH004	Employee Workstations	Inadequate Backup	- Lack of regular backups, leading to potential data loss.
PH005	Safe	Break-In Through Window	- Safe is proximity to a window, allowing to break window and direct access it.
PH006	Office Supplies	Vandalism	- Lack of monitoring in storage areas.
PH007	Intelligent Airflow	System Failure	- No backup airflow systems in place when single point of failure occur.
D001	Transactional Data	Backup Failure	- Inadequate backup, backup every Friday.
D002	Customer Data	Data Corruption	- Lack of data integrity checks.
D003	Backup Data	Data Breach	- Backup data stored without encryption.
D004	Administrative Data	Insider Threat	- Lack of monitoring and auditing.
D005	Employee Records	Data Loss	- Inadequate backup. -
D006	Service Information	Phishing and Social Engineering	- Exploited by attackers through phishing or social engineering

Risk Assessment

The analysis of the system's vulnerabilities, the threats associated with them, and the probable impact of that vulnerability exploitation results in a risk rating for each missing or partially implemented control. The risk level is determined on the following two factors:

1. Likelihood of Occurrence
   It is the probability that a specific vulnerability within EtherSpace will occur.
2. Impact
   It is the consequence of an event, if it occurs.

The risk rating is the point where the likelihood and impact ratings intersect.

Impact	Severe	15	19	22	24	25
	Significant	10	14	18	21	23
	Moderate	6	9	13	17	20
	Minor	3	5	8	12	16

	Minimal	1	2	4	7	11
		Almost never	Possible but unlikely	Possible	Highly probable	Certain
		Likelihood				

Security Risks

Risk ID	Asset ID	Threat	Vulnerability	Risk Description	Consequence	Gross Risk		
						Impact	Likelihood	Risk Rating
R001	P001, P002, P003	Unauthorised access	Weak password policies	Unauthorised access to sensitive data and systems through compromised credentials.	- Severe impact on business operations. - potential breach of SLAs, legal liabilities. - loss of corporate image.	Severe	Possible	22
R002	H001, H002, H003	Physical theft	Inadequate physical security measures.	Theft of hardware and data by unauthorised personnel accessing the office.	- Significant economic loss. - Disruption of critical operations. - Potential legal liabilities.	Severe	Possible but unlikely	19
R003	H010, H011	Data interception	Data not encrypted during transmission	Sensitive customer data intercepted during transmission between servers and clients.	- Breach of confidentiality leading to severe legal liabilities. - Significant loss of customer trust. - Economic loss.	Severe	Possible	22
R004	P001, P002, P003	Insider threats	Lack of employee background checks	Employees with malicious intent or negligence causing data breaches or operational disruptions.	- Considerable economic loss - Significant legal implications - Substantial impact on corporate image.	Significant	Possible	18
R005	H001, H002, H003, H004, H005, H007, H008, H009	Fire	Lack of fire suppression systems	Fire causing extensive damage to hardware and data loss.	- Severe impact on business operations - Possible breach of SLAs - Substantial financial loss due to hardware damage.	Severe	Almost never	15

R006	H001, H002, H003, H004, H005, H007, H008, H009	Flood	Lack of water damage prevention	Flooding causing damage to hardware and data loss.	- Severe impact on business operations - Possible breach of SLAs - Substantial financial loss due to hardware damage.	Severe	Almost never	15
R007	H001, H002, H003, H004, H005, H007, H008, H009	Earthquake	Inadequate building structure	Earthquake causing structural damage and data loss.	- Severe impact on business operations - Potential loss of life - Major economic loss due to infrastructure damage.	Severe	Almost never	15
R008	H001, H002, H003, H004, H005, H007, H008, H009	Power Outage	Lack of backup power systems	Power outage causing service unavailable and data loss.	- Severe impact on business operation - Legal implications due to downtime - Significant financial loss.	Severe	Possible but unlikely	19
R009	H001, H003, H009	System failures	Lack of redundant systems	Critical system failures causing service outages.	- Severe disruption of business operations. - Potential legal implications. - Significant loss of revenue.	Severe	Possible	22
R010	H001, H002	Malware and viruses	Inadequate malware protection	Malicious software infecting systems and causing data corruption or loss.	- Severe impact on business operations. - Major data breaches, legal liabilities. - Loss of customer trust.	Severe	Possible	22
R011	D003	Data loss	Inadequate backup procedures	Permanent loss of critical data due to insufficient backup systems.	- Significant economic loss. - Disruption of business operations. - Potential legal liabilities.	Significant	Possible	18
R012	D004	Unauthorised modification	Lack of access controls for administrative data	Unauthorised changes to critical data by unapproved personnel.	- Severe impact on data integrity. - Legal liabilities. - Significant economic loss due to	Severe	Possible	22

					incorrect data processing.			
R013	P001, P002, P003	Social engineering	Lack of employee training on phishing	Employees falling victim to phishing attacks, leading to data breaches or credential theft.	- Significant economic loss. - Legal liabilities. - Damage to corporate image due to compromised credentials.	Significant	Possible but unlikely	14
R014	S001, S002, S003, S004, S006, S007	Unpatched software	Lack of software updates	Exploitation of software vulnerabilities due to lack of updates.	- Severe impact on business operations. - Data breaches. - Legal liabilities. - Loss of customer trust.	Severe	Possible	22
R015	S001, S002, S003, S004, S006, S007	Software bugs	Lack of quality assurance	Bugs in software causing data corruption or loss.	- Severe impact on business operations. - Legal liabilities. - Significant economic loss due to incorrect data processing.	Significant	Possible	18
R016	S001, S002, S003, S004, S006, S007	Misconfigure d software	Lack of configuration management	Misconfigurations causing security vulnerabilities.	- Severe impact on business operations. - Potential data breaches. - Significant legal liabilities.	Severe	Possible	22
R017	PH001, PH002, PH003, PH004, PH005, PH006	Vandalism	Lack of physical security	Vandalism causing damage to hardware and infrastructure.	- Severe impact on business operations - Potential legal implications - Significant economic loss due to hardware damage.	Significant	Possible but unlikely	14

R018	PH001, PH002, PH003, PH004, PH005, PH006	Theft	Inadequate physical protection	Theft of hardware causing operational disruption.	- Severe impact on business operations - Significant financial loss. - Potential legal liabilities.	Significant	Possible	18
R019	PH001, PH002, PH003, PH004, PH005, PH006	Natural disasters	Lack of structural integrity	Natural disasters causing extensive damage to infrastructure.	- Severe impact on business operations, potential loss of life. - Significant economic loss due to infrastructure damage.	Severe	Possible but unlikely	19

Risk Controls

The Risk Controls is to mitigate the identified risks. The table provides an overview of pre-existing safeguards and a recommended measures to mitigate identified risks.

Recommended Controls

Risk ID	Existing safeguards	Recommended Controls
R001	Strong password policy for engineers	Implement multi-factor authentication for all critical systems.
R002	Basic physical security measures	Enhance physical security with biometric access controls, security cameras, and 24/7 monitoring.
R003	None	Implement end-to-end encryption for all data in transit.
R004	None	Conduct thorough background checks during the hiring process.
R005	Basic fire detection and suppression systems	Develop a complete disaster recovery plan that including additional fire suppression systems and online backup or cloud servers.
R006	None	Implement water damage prevention measures.
R007	None	Strengthen building structure to withstand earthquakes.
R008	None	Install backup power systems using generators.
R009	None	Implement redundant systems for critical infrastructure to ensure high availability.

R010	Basic antivirus software	Deploy advanced malware protection and conduct regular security training for employees.
R011	Weekly backups on NAS	Implement daily backups with offsite storage and regular verification.
R012	None	Implement strict access controls and regular audits of the data.
R013	None	Conduct regular training sessions on social engineering and phishing awareness for all employees.
R014	Basic software patching	Regularly update and patch software to fix vulnerabilities.
R015	None	Regular software testing and validation.
R016	None	Develop and enforce strict configuration management practices.
R017	Basic physical protection measures	Install security cameras and reinforce building entry points.
R018	Basic physical protection measures	Implement advanced physical protection systems that includes secure locks and alarms.
R019	None	Strengthen structural integrity against natural disasters.

Reference List

Whitman, M.E., Mattord, H.J. (2014). *Principles of Information Security* (5th ed.). United States of America: Cengage Learning

[1] "Classify information," *New Zealand Digital government*, Oct. 04, 2019. https://www.digital.govt.nz/standards-and-guidance/governance/managing-online-channels/security-and-privacy-for-websites/foundations/classify-information/

[2] "Why Apache OpenOffice," *www.openoffice.org*. https://www.openoffice.org/why/

[3] "[AD-008] How Organisations Can Secure Their Network Attached Storage (NAS) Systems," *Default*. https://www.csa.gov.sg/alerts-advisories/Advisories/2024/ad-2024-008#:~:text=Once%20attackers%20gain%20access%20to

[4] S. Ohayon, "The Risks of Expired SSL Certificates Explained - CrowdStrike," *crowdstrike.com*, Aug. 01, 2022. https://www.crowdstrike.com/blog/the-risks-of-expired-ssl-certificates/

[5] "Announcing Apache OpenOffice 4.1.15," *openoffice.apache.org*, Dec. 22, 2023. https://openoffice.apache.org/blog/announcing-apache-openoffice-4-1-15.html

[6] "Complete List of Hypervisor Vulnerabilities," *HitechNectar*. https://www.hitechnectar.com/blogs/hypervisor-vulnerabilities/